MicroFinCo ISO 27001 Test Scope & Authorization

Document ID: MFC-ISMS-TS-001 | **Version:** 1.0 **Authorization date:** 30 October 2026 **Test window:** 9 November 2026 – 13 November 2026, 09:00–17:00 PKT

1. Purpose

This document defines the scope and rules of engagement for security testing of the MicroFinCo staging environment, in support of the Information Security Management System (ISMS) under ISO/IEC 27001. It records the board's formal authorization. No testing may begin outside the scope below.

2. Environment Details

Item	Detail
Environment	Staging (isolated from production)
Network range	10.20.30.0/24 (fictional)
Hosting	Private cloud VPC, region ap-south
Data	Synthetic only; no real customer data
Test team	Internal Security Team (lead: A. Khan)

3. In-Scope Assets

ID	Asset	Test activity	Risk assessment ref.
S-01	Loan portal web app (staging.microfinco.example)	Vulnerability scan, OWASP Top 10 checks	RA-2026-04
S-02	Customer API (10.20.30.15)	Authentication and authorization testing	RA-2026-05
S-03	Database server (10.20.30.20)	Configuration review, access control checks	RA-2026-06
S-04	Admin VPN gateway (10.20.30.5)	Patch level and configuration audit	RA-2026-07
S-05	Employee workstations (staging VLAN)	Endpoint hardening review	RA-2026-08

4. Boundaries (Out of Scope)

- Production systems, networks, and data
- Third-party and vendor-hosted services
- Denial-of-service or stress testing

- Social engineering and physical intrusion
- Data exfiltration beyond proof of access (screenshots only)
- Any asset not listed in Section 3

5. Rules of Engagement

1. Testing runs only inside the approved window.
2. Testers use named, logged accounts and the approved source IP.
3. Critical findings are reported to the ISMS Manager within 2 hours.
4. Testing stops immediately on any service-impact incident.
5. Findings feed the risk treatment plan and the Statement of Applicability (SoA) review.
6. All evidence is stored per the document control procedure and deleted after 12 months.

6. Related ISO 27001 Controls

Annex A 8.8 (management of technical vulnerabilities), 8.29 (security testing in development and acceptance), 5.36 (compliance with policies and standards).

7. Board Authorization

The undersigned authorize testing as defined above.

Name / Role	Signature	Date
Board Chair (fictional)	_____	____ / ____ / _____
Chief Information Security Officer (fictional)	_____	____ / ____ / _____
Board Member (fictional)	_____	____ / ____ / _____